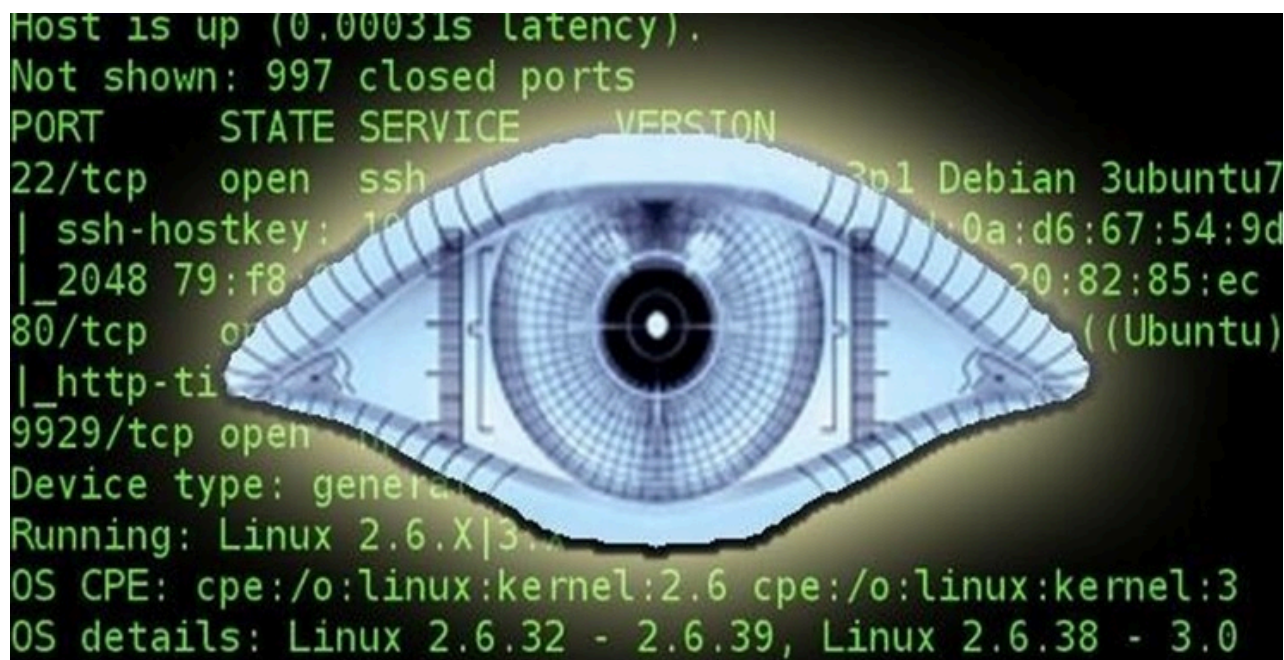


nmap for Recon and DoS

 hackers-arise.com/nmap-for-recon-and-dos



Welcome back, my nascent Hackers!

In previous articles , we looked at a passive way to gather information necessary for a hack. The advantage of using passive recon is that it's totally undetectable, meaning that the target never knows you're scouting them and you leave no tracks. The disadvantage, of course, is that it's limited to only some websites and not entirely reliable.

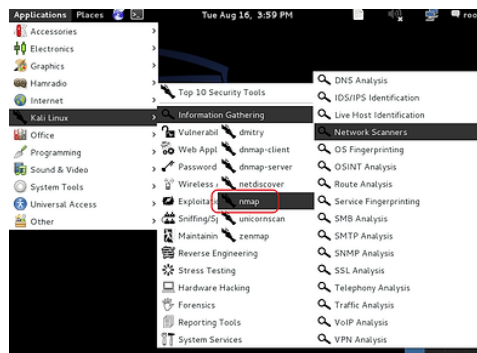


In this tutorial, we'll look at active reconnaissance of a target with one of the best network scanning tools, nmap.

The risk with active scanning is that you will be detected and the security hardware or security admin will block any further attempts by you to pwn the site, or worse—report you to law enforcement. Nmap has multiple modes of scanning a potential target and many ways of evading detection.

Step 1 Open nmap

Let's go to our hacking platform, Kali or BackTrack, and open up nmap. To find it, go the BackTrack button at the bottom left of the screen to open up the initial menu options. Then, select Applications -> Kali Linux -> Information Gathering ->Network Scanners, and click on nmap.

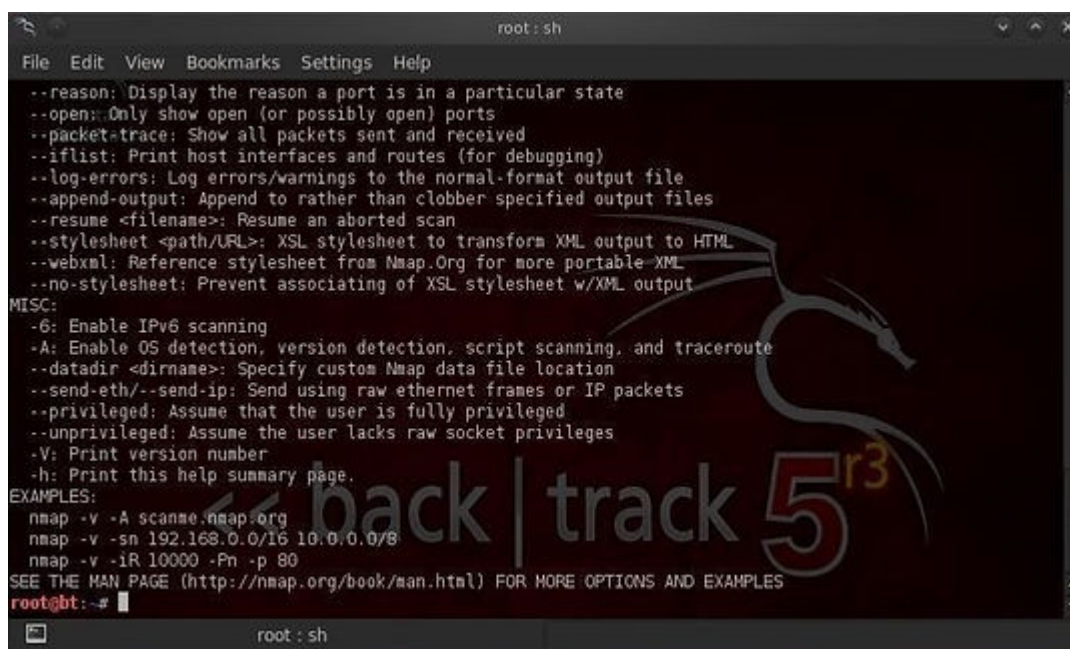


You can also start nmap by simply typing nmap at the command prompt.

```
kali > nmap
```

Step 2 Using Nmap

When you select nmap, you'll open a screen that looks like the screenshot below.



Note that it opens a Linux terminal with the help screen for nmap (also, although these screenshots are for BackTrack, nmap works identically in Kali). Whenever you want to see the help screen, you can simply type at the command prompt:

```
kali > nmap -h
```

You can also get the manual for nmap by typing:

kali > man nmap

Nmap is a delightful tool for gathering information on a network or site. For instance, if we want to gather information on ESPN.com, we can type:

kali > nmap -sT espn.com

We can see some of the output below.

```
root@bt:~# nmap -sT espn.com
Starting Nmap 6.01 ( http://nmap.org ) at 2013-05-17 18:20 MDT
Nmap scan report for espn.com (199.181.132.250)
Host is up (0.057s latency).
Not shown: 995 closed ports
PORT      STATE      SERVICE
25/tcp    filtered  smtp
80/tcp    open      http
135/tcp    filtered  msrpc
139/tcp    filtered  netbios-ssn
445/tcp    filtered  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 15.92 seconds
root@bt:~#
```

This command tells nmap to scan (-s) using TCP (T) the domain espn.com. Note that the output shows us the ports that this web server has open. With this information, we can then reasonably conclude that the default services for these ports are running on this system. In this case, this server has port 25 open (SMTP), port 80 open (HTTP), port 135 open (msrpc), port 139 open (net-bios), and port 445 (msds).

This is important information to have when selecting a hack/exploit as each hack is specific to technologies/services.

Step 3 Operating System Detection

Nmap is also capable of detecting and making a guess as to what the operating system is. Type:

kali > nmap -O espn.com


```
root: nmap
File Edit View Bookmarks Settings Help
Starting Nmap 6.01 ( http://nmap.org ) at 2013-05-17 18:27 MDT
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.06 seconds
root@bt:~# nmap -O espn.com

Starting Nmap 6.01 ( http://nmap.org ) at 2013-05-17 18:27 MDT
Nmap scan report for espn.com (199.181.132.250)
Host is up (0.062s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE
25/tcp    filtered smtp
80/tcp    open  http
135/tcp    filtered msrpc
139/tcp    filtered netbios-ssn
445/tcp    filtered microsoft-ds
Device type: load balancer|general purpose
Running (JUST GUESSING): F5 Networks embedded (93%), OpenBSD 4.X (85%)
OS CPE: cpe:/o:openbsd:openbsd:4
Aggressive OS guesses: F5 BIG-IP 3650 Local Traffic Manager load balancer (93%), OpenBSD 4.2 - 4.4 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 14 hops

OS detection performed. Please report any incorrect results at http://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.65 seconds
root@bt:~#
```

We can see from the screenshot above that nmap guessed that this site is running F5 Networks with a 93% probability and OpenBSD with a lower 85% probability. nmap is not the best tool for OS fingerprinting.

Step 4 Stealth Scan

The above scan by nmap is highly reliable, but its drawback is that it's also easily detectable. Nearly every system admin will know that you're scanning their network as it creates a full TCP connection, and this is logged with your IP address in the log files. *← And you'll get caught*

A more stealthy scan can be conducted using the -sS switch in nmap. This scan uses SYN flagged packets that do NOT create a connection on the target machine and therefore are not logged. This type of scan is slightly less reliable, but is much more stealthy. Type:

```
kali> nmap -sS espn.com
```

```
root: nmap
File Edit View Bookmarks Settings Help
Aggressive OS guesses: F5 BIG-IP 3650 Local Traffic Manager load balancer (93%), OpenBSD 4.2 - 4.4 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 14 hops

OS detection performed. Please report any incorrect results at http://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.65 seconds
root@bt:~# nmap -sU espn.com

Starting Nmap 6.01 ( http://nmap.org ) at 2013-05-18 16:26 MDT
root@bt:~# nmap -sS espn.com

Starting Nmap 6.01 ( http://nmap.org ) at 2013-05-18 16:27 MDT
Nmap scan report for espn.com (199.181.132.250)
Host is up (0.078s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE
25/tcp    filtered smtp
80/tcp    open  http
135/tcp    filtered msrpc
139/tcp    filtered netbios-ssn
445/tcp    filtered microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 17.56 seconds
root@bt:~#
```

As we can see in the screenshot above, it gave us the same results without our activity being logged by the target system.

Step 5 Evading Intrusion Detection Systems

Most commercial servers and websites have **intrusion detection systems (IDS)** protecting them. These systems look for telltale signs of malicious activity, then alert the security administrator. Scans such as ours are easily detected by these systems and can set off an alert.

However, there are numerous ways to evade these IDSs, and we'll look at one here.

IDSs usually have a **threshold setting**. This means that if it sees numerous packets that appear to be scans, then it will alert the admin. To avoid detection, we can simply slow down our scan below this threshold. Nmap has numerous speed settings. Here we'll use the "sneaky" speed setting. Let's type: `kali > nmap -sS -T2 espn.com`

```
File Edit View Bookmarks Settings Help
root@bt:~# nmap -sS -T2 espn.com
Install
Starting Nmap 6.01 ( http://nmap.org ) at 2013-05-18 16:35 MDT
Nmap scan report for espn.com (199.181.132.250)
Host is up (0.067s latency).
Not shown: 995 closed ports
PORT      STATE      SERVICE
25/tcp    filtered  smtp
80/tcp    open      http
135/tcp   filtered  msrpc
139/tcp   filtered  netbios-ssn
445/tcp   filtered  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 420.07 seconds
root@bt:~#
```

The **-T2 setting** tells nmap to use the **sneaky speed**. This scan will likely take longer, but it is much more likely to go undetected by the IDS.

One Final Note

Nmap can also be an **excellent denial of service (DOS) tool**. If **several individuals** all send packets from nmap at a target simultaneously at high speed (nmap "insane" speed or -T5), they're likely to overwhelm the target and it will be unable to process new website requests effectively, rendering it useless.

We'll continue with more reconnaissance techniques in future tutorials, so keep coming back!

DDOS